Hardening the Compliance Report Generator

How 22 pull requests and an updated AUDIT-CRITERIA.md turned a draft agent into one whose guarantees are tested, traceable and honest about their limits

For auditors and developers | PRs #5, #17-#38 | 6 October 2026

OVERVIEW

One day, 22 pull requests

20	1	1	202
merged	open (#38)	closed unmerged (#22)	tests passing in CI on main

- Scope: PR #5 (AUDIT-CRITERIA.md created) and PRs #17 to #38, all opened or closed on 6 Oct 2026.
- Themes: grounded scoping, valid output, transparent decision support, data and secrets handling, traceability, and CI guardrails.
- Every change maps back to a control objective (CO-1 to CO-5) in AUDIT-CRITERIA.md, so the claims can be checked.
- PR #22 (ownership / PDCA wording) was closed without merging; the matching gap was later removed in #38.

BASELINE (PR #5)

Starting point: gaps the audit named honestly

AUDIT-CRITERIA.md v1 defined five control objectives and recorded these known gaps, with no test evidence run:

No grounding check

Model could cite frameworks outside the mapped set.

Disclaimer overridable

The model could rewrite the legal disclaimer.

Clause references unverified

Invented article or section numbers went unflagged.

Entity name sent unredacted

company_name went to the API with no warning.

No run() tests; timeout unused

Retry and failure paths untested; Config.timeout_seconds ignored.

No audit trail

No persistent record of what a run sent or received.

HARDENING MAP

Gap to fix: what changed

Gap in v1	Fix	PR
Out-of-scope frameworks accepted	Grounding check; fails closed	#25
Clause references unverified	Reference flags, then official clause lists for 10 frameworks	#21, #34
Disclaimer overridable	Constant forced after validation; removed from model schema	#23
Unrecognised jurisdiction silent	Warning in CLI, report and JSON	#24
Entity name unredacted	Data-flow warning and opt-in alias	#26
Timeout unused; run() untested	Timeout passed to client; mocked-client tests	#17, #27
No audit trail / no export	Opt-in audit trail; finding-schema export	#18, #19
Knowledge base undated	Version, source and last_reviewed fields; BIO2 added	#20, #36
No automated gates	Test CI, Ruff lint, weekly clause e2e	#29, #33, #37

AUDIT CYCLE

What hardening buys at each stage of the audit cycle

1. Preparation

Scope and plan

- Grounding check keeps scope to the frameworks the mapper selected (#25)
- Jurisdiction warning flags a scope the KB cannot cover (#24)
- Versioned, sourced KB; BIO2 added (#20, #36)
- Model and endpoint chosen explicitly and safely (#31)

2. Fieldwork

Run and gather

- Entity-name warning and alias before data leaves (#26)
- Timeout and retry rules tested (#17, #27)
- Opt-in audit trail records inputs, model, prompt hash, response (#18)
- No secrets in tracked files (#38)

3. Analysis

Test and evaluate

- Clause references checked against official text, ranked by confidence (#34)
- Unmapped names rejected, unknown references flagged (#21, #25)
- Weekly e2e catches clause-list drift (#37)
- Auditor reviews flagged items first

4. Reporting

Conclude and communicate

- Disclaimer cannot be rewritten by the model (#23)
- Findings export in finding-schema.json (#19)
- Output schema-validated; warnings travel with the report (#24)
- Evidence table in AUDIT-CRITERIA.md backed by CI (#38)

The agent still supports the auditor's judgement; it does not conclude. Every output carries the disclaimer and its references stay labelled unverified.

Grounded scoping: the model cannot widen the scope

Grounding check (#25)

Every framework and regulation name in the output is compared with the deterministic mapping. Anything unmapped raises ComplianceReportError and keeps raw_response. Fails closed.

Reference flags (#21)

requirement_source and applicable_sections that name no mapped framework are flagged, logged, and noted in the report as model-generated and unverified.

Jurisdiction warning (#24)

A country that does not resolve to a known jurisdiction produces a visible warning, including on --dry-run, and a warnings field in JSON.

- Tested with mocked model output: SOX for a US private Healthcare profile is rejected; an invented regulation is rejected.
- Limit: matching is by name heuristic, so a legitimate rewording can be rejected rather than flagged.

CO-1 | ANALYSIS | #34 AND #37

Clause references checked against official text

10 frameworks, 12.5k lines

GDPR, UK GDPR, DORA, NIS2, MiFID II, HIPAA, GLBA, NIST CSF 2.0, NIST 800-53, CCPA/CPRA. Source, version and retrieval date stored per list.

Parsed from sources, not memory

Extraction scripts in tools/clause_sources/ read EU OJ, legislation.gov.uk, eCFR, govinfo, California and NIST; stdlib only, re-runnable.

Label, never reject

Each reference gets status unverified and a confidence below 1.0. Mismatches warn and are ranked for review.

- New report-level reference_checks field is agent-generated only: any model-supplied value is dropped.
- #37 adds a weekly end-to-end job that re-fetches live sources and fails if the committed lists have drifted.
- Still open: 19 of 29 frameworks have no clause list, and the confidence numbers are a maintainer judgement call.

Valid, tamper-resistant output

Disclaimer is not model-controlled (#23)

DISCLAIMER is a constant, removed from the JSON schema shown to the model, and re-applied after validation. A model-supplied disclaimer is logged and discarded.

Failure paths are tested (#27)

Mocked-client tests cover fenced and prose-wrapped JSON, no-JSON and schema-invalid responses, 4xx fail-fast, and 5xx or connection retries.

- Same pattern for warnings and reference_checks: agent-owned fields are stripped from the model schema.
- #17 passes Config.timeout_seconds to the client, so the configured timeout is now real.
- Verified against mocked responses only; no live model run backs these criteria.

Data and secrets handling

Entity name warning (#26)

Before a real call the CLI warns that company_name goes to the LLM API verbatim. --yes or --no-warn suppresses it.

Opt-in anonymising (#26)

--anonymise or --alias sends a placeholder (default Entity A). Logs only see the alias; the real name is restored locally.

Endpoint safety (#31)

Base URL must be http(s) with no credentials; plain http to a non-local host warns; redirects are never followed, so the key cannot be forwarded.

- Secrets scan of tracked files on main (sk-, AKIA, private-key headers, tracked .env): no matches (#38).
- Limit: anonymising is opt-in, and industry, country and topic are still sent.

Traceability: what ran, with what, and what it said

Audit trail (#18, #31)

--audit-trail-dir writes <report_id>.json: inputs, framework keys, model, prompt hash, timestamps, raw response. Company name redacted by default. v2 adds provider, sanitised endpoint, attempts, tokens.

Findings export (#19)

--output findings converts key and critical gaps into finding-schema.json findings. Critical maps to High; optional fields are omitted rather than invented.

Knowledge base metadata (#20, #36)

KB_VERSION plus per-framework source and last_reviewed. BIO2 added with its Staatscourant source and review date.

- Limit: failed runs get no audit record, and last_reviewed is empty for most frameworks (tracked in #30).

PREPARATION | #31

Provider-independent, without weaker checks

- New LLMClient interface with two providers: anthropic (default, unchanged) and openai (any OpenAI-compatible endpoint: vLLM, Ollama, LiteLLM, LM Studio).
- Flags --provider, --model, --base-url with SAAF_* environment variables; precedence is flag, then env, then default.
- Whatever model answers, the same schema validation, grounding check and reference checks apply.
- Tested against a real local HTTP server: request shape, 4xx/5xx, connection refused, malformed responses, redirect refusal.
- Honest limit: only claude-opus-4-6 has been used; quality and JSON compliance vary by model, and a custom endpoint sees the same data as the default.

ENGINEERING

Guardrails that keep the hardening in place

Tests on every PR (#29)

GitHub Actions runs the unittest suite on PRs and main, with a per-PR report comment and JUnit artifact.

Ruff static analysis (#33)

Rules E, F, W, I, B on PRs and main. Existing findings fixed with no behaviour change.

Clause-source e2e (#37)

Weekly, manual, and on clause-data PRs. Re-runs extraction against live sources and fails on drift.

- Result on main (run 37473476071): 202 passed, 1 skipped.
- Lint was failing on main (I001 in the #37 e2e test); the fix is part of #38.

UPDATING THE STANDARD

AUDIT-CRITERIA.md: from draft claims to CI-backed evidence

	v1 (PR #5)	Now (PR #38, open)
Evidence	Nothing run; only a manual secrets scan	Every checked row cites tests that passed in CI on main
Criteria	5 control objectives	Plus clause checking, findings export, provider independence, richer log line
Gaps	Six recorded, none fixed	Timeout and ownership gaps removed; others narrowed to what remains
Output fields	Report only	reference_checks documented; findings export described with limits
Status	Draft	Still Draft, deliberately

Each hardening PR edited the document in the same change: it names the criterion addressed, marks a row verified only for what its tests show, and narrows the matching gap.

EVIDENCE DISCIPLINE

What 'verified' means here

- A row is checked only if a named test passed in the Tests workflow on main; #38 downloaded the JUnit results and confirmed each cited test exists.
- PR descriptions state what was not run, for example early PRs that could not execute the suite locally.
- Mocked tests are labelled as such. No criterion is claimed from a live model run.
- #22 (maintainers and PDCA status) was closed without merging, and the ownership gap was dropped from the document in #38 rather than papered over.

HONEST LIMITS

What is still open

Not yet tested

No test or run uses a real model. The OpenAI-compatible path has never run against one.

Coverage gaps

19 of 29 frameworks lack clause lists. last_reviewed is empty for most entries (#30). Confidence values need maintainer review.

Rows still unchecked

System-prompt criterion, 'no compliance conclusion' (prompt wording only), stderr-log and JSON-field criteria (code inspection).

- Next: merge #38, make the Test report check required, fill source and last_reviewed, then run against a live model.